

TLP:CLEAR

The "UN Compensation" Scam

A look at the run, and at the host that carried it. September 2026

Advance-fee fraud | Sender spoofing | Bulletproof hosting | Rebrand

Parameter	Value
Event window	26 August – 12 September 2026 (UTC)
Date of analysis	13 September 2026
Classification	TLP:CLEAR
Threat level	LOW
Threat type	Advance-fee fraud ("419"). No malicious code.
Recipient	A human rights NGO, at the contact address on its website
Outcome	The mail did not reach the organisation's mailboxes. No reply went out from them.

1. In short

Overnight on 1–2 September 2026, a human rights NGO received three scam emails. All three came from the same server, over seven and a half hours, under three different made-up names. None of them contained a link or an attachment.

The scheme is an old one. The recipient is told that compensation is waiting for them from a United Nations body, and invited to get in touch with a "director". Everything then depends on the victim replying. Once they do, a correspondence begins in which they are asked for money — a processing fee, a transfer fee, an insurance premium. There is, of course, no compensation.

The mail did not reach the organisation's mailboxes, and no reply went out from them. How far that check actually extends is set out in section 9. As an incident this is unremarkable; millions of these are sent. What is worth a closer look is whose server this was.

Two of the provider's networks are on the Spamhaus ASN-DROP list in their entirety, and its whole address block is on the DROP list. And eleven days after the run, it spent about seven hours changing its name, its country of registration, and the network number it uses to reach the internet. Section 5 walks through how. That is more interesting than the mail itself, because it shows how long attribution to a hosting company's name stays worth anything.

One more thing: this was not a targeted run, even though it looks like one. The match between a UN compensation story and a human rights organisation is a coincidence. Section 4 explains why we are confident of that.

2. What was in the emails

Three emails, three characters, one sender. The first two arrived in the same second.

#	Time (UTC)	Who the sender claimed to be	Subject
1	01.09 17:18:26	"Director of Compensation" at a UN body that does not exist	Reference No. UNCC/2026/0817/00427 – Notice
2	01.09 17:18:26	A "doctor" who had supposedly written before	Did You Receive My Previous Message?
3	02.09 00:51:47	A "broker" with something to invest in	Exploring a Funding Partnership

The second email pretends to be a follow-up, but there was no first one. It was sent in the same second as the other, only under a different name and from a different address. The trick is meant to make the reader doubt their own memory and go looking for a message that was never there. There is nothing to look for: before 1 September this sender had never written to the organisation.

No body called the "United Nations Human Development Compensation Commission" exists. The name is stitched together from two real ones: the UN Development Programme and the UN Compensation Commission.

That Commission was real. It was set up in 1991 to handle claims arising from Iraq's invasion of Kuwait. Its mandate ended in February 2022, and it was formally closed on 9 December 2022. Even while it was

running, though, it never paid individuals — only governments, which then distributed the money to claimants. The Commission said so explicitly, and warned that it had no agents, no intermediary banks and no offices outside Geneva.

The emails are written in calm, businesslike English: no sums spelled out, no capital letters every other line, no "reply within 24 hours". That sets them apart from the classic examples of the genre. What follows from it, we do not know, and we are not going to guess.

Whose names were used

The first two emails were sent in the name of two real companies: a logistics firm in Saudi Arabia and a financial advisory firm in Slovenia. Neither had anything to do with it. Their domain names were borrowed without their knowledge, and they are as much on the receiving end as the NGO was.

That is why we left those domains out of the indicator list and out of the machine-readable exports. Lists like these are often loaded into blocking systems automatically, unread — and what then gets blocked is not the scammer, but the company whose name he took.

Curiously, the sender clearly did not pick those domains for being poorly defended. Both have their mail records set up strictly, and one of them additionally rejects forgeries outright and sends complaints to a national response centre. None of the three emails passed authentication, and the sender evidently never expected them to: the bet is on volume, not on getting delivered. The third email was sent in the name of the recipient's own domain — which is a stock feature of bulk-mail software and takes no preparation at all.

3. Why mail like this is hard to catch

There are no links, attachments, forms or phone numbers in these emails. For a mail filter that means there is nothing to work with: nothing to open in a sandbox, nothing to look up in a reputation feed, no redirect chain to follow. All that is left is a failed sender check and a reply address at a free mail provider.

This is not laziness on the sender's part. It is the design. Everything dangerous happens later, in the correspondence, where the mail filter no longer looks.

The practical conclusion is simple: a rule that needs to find a link or an attachment will never see these emails. Do not rely on one.

4. Why we think the run was not targeted

The subject — compensation from a UN body — sits suspiciously well on a human rights organisation. We tested that reading and rejected it.

There is one argument for it, and only one: all three emails went to a single address, rather than being sprayed across the organisation. But that address is published on the website as the main point of contact, and any harvesting script will pick it up. It is the busiest inbound address the organisation has. One address on a sender's list means one harvest, not a choice of victim.

Against the targeted reading: there is nothing about the recipient in any of the emails. No staff name, no case number, no mention of what the organisation actually does. The template is generic. The sender did not even bother to learn that the commission he was writing on behalf of closed four years ago.

We watch the mail of three organisations with no connection to one another. The share of this kind of message in their traffic is almost identical — between one and one and a half per cent. This organisation does not stand out in any way.

And three days before all this, the same sender used the same server to write to a different victim: a transport company in the Czech Republic, with no connection to human rights work.

He spent nothing on preparation. No domain bought, no fake page built, no research on the victim. The conclusion: an ordinary bulk run, in which the match between subject and recipient is coincidence.

5. The server, the host, and the change of name

The server the mail came from was not rented for the evening. We have been seeing this address for at least seven months, used for varied purposes: in February and March it was pointed at by domains selling game cheats and by a bulk-mail service, and the first of those still points at it today.

When we looked into who owns it, it turned out that the name in the registry is not the level worth keeping records at. The network is held by a parent company; the one named in the record is just a tenant and a trading name. Both are administered by the same private technical contact, whose description names the owner outright.

Why we consider this hosting criminal

- Two of the owner's networks are on the Spamhaus ASN-DROP list. That list is not for individual offenders; it is for networks considered criminal as a whole.
- Another Spamhaus list, DROP, covers the owner's entire address block — including the part he rents to nobody and uses himself.
- The host has no website. The main brand's domain answers with a loopback address, and the domains for the new brand and for abuse complaints have no address records at all. We take that to mean customers are found somewhere other than a shop window, which is not how legitimate hosting works.
- One of the networks is used as a staging post: around twenty-eight address blocks passed through it during 2025 and 2026, each held for anything from a few weeks to a few months.

How the name was changed in seven hours

Eleven days after the run, the owner of the infrastructure changed its trading identity. The whole thing took about seven hours.

At 09:35 UTC a new domain was registered. At 10:16 the service contacts were updated — the abuse address first, the administrative one twenty-three seconds later. At 10:24 the record for the network itself was rewritten, and at 10:25 the record for the company: the old name and a Luxembourg address gave way to a new name and an address in Vilnius, with the record's internal handle unchanged. In other words the entire registration was rewritten in nine minutes, not one field of it. By around 16:00 the announcement of the address blocks had moved to a different network number, dormant since May. Finally, the record for the old number was deleted from the regional registry's database.

That this is the same people is visible from the machine-readable geolocation file the new record points to: it lists exactly the same set of address blocks the old brand had. And the unchanged record handle says the company was renamed, not sold.

The takeaway for anyone keeping files like these: blocking a specific address still makes sense, but the file should be kept on the owner of the network and its technical contact. In this case, attribution to a company name and a network number lasted eleven days.

6. Two mistakes we made ourselves

The first concerns how abusive hosting is identified. There is a common test: count how many networks were registered through the same intermediary. A lot of networks is a bad sign. We ran it and got hundreds, which looked like a verdict. In fact this was an ordinary commercial intermediary that registers networks for anyone, and its figures say nothing about the quality of any particular network. The test had to be thrown out.

What did work, and what we would suggest instead: presence on blocklists that operate at whole-network granularity rather than per-address; coverage of the part of the block the owner does not rent out; the absence of a website; and observable shuffling of address blocks.

The second mistake concerns decoys. Neither this server nor five neighbouring blocks belonging to the same owner touched our traps once in six months. It is tempting to read that as a clean bill of health, and it would be wrong. Mail servers at a host like this do mail and nothing else; they do not scan networks. Other tenants of the same blocks do. If you are assessing mail infrastructure, an absence of traces in decoy data means nothing.

7. Indicators

Addresses are written in a defanged form so that nothing can be clicked by accident. The domains the sender wrote in the name of are not in the list: they belong to uninvolved companies.

Type	Value	Note
IPv4	64.89.161[.]75	Sending relay, Netiface / Ghosty Networks
ASN	AS205759	Announced the prefix at the time of the run; removed from RIPE on 2026-09-12
ASN	AS36680	Netiface LLC; listed in Spamhaus ASN-DROP
ASN	AS401626	Netiface Toronto; listed in Spamhaus ASN-DROP
E-mail	alexanderdecro@outlook[.]com	Reply channel, message 1
E-mail	ddmndroid@gmail[.]com	Reply channel, message 2
E-mail	brokerjamesandy@gmail[.]com	Reply channel, message 3
E-mail	brokerjamesady@mailingbin[.]com	Same operator, 2026-08-29, unrelated victim
Domain	blatant[.]host	Operator's new brand, registered 2026-09-12
Domain	ghostynetworks[.]com	Former brand; A record 127.0.0.127
Domain	nfx[.]rip	Abuse-contact domain; no A record

We are not proposing the provider's network for blocking, even though it is on the blocklists. A block that size would catch tenants who had nothing to do with this, and since the owner shuffles his address blocks constantly, it would go stale quickly. One address is worth blocking: the one the mail came from.

MITRE ATT&CK techniques: T1585.002 (setting up email accounts), T1656 (impersonation), T1583.001 (acquiring domains). We should note that this is fraud rather than intrusion, and the classification only covers part of it.

8. What we would suggest

- Do not count on rules that look for a link or an attachment in the message. In mail of this kind there is neither.
- Treat it as a warning sign in its own right when the reply address is on a different domain from the sender address and the authentication check has failed.
- Check whether the mailbox you have listed for receiving forgery complaints about your domain is still alive. If the complaints do not arrive, or nobody reads them, the channel is useless.
- Do not block the domains a message came in the name of without checking. In schemes like this they almost always belong to bystanders.
- Keep your hosting files on the owner of the network, not on the company name and network number: here, both changed in a day.

9. What we do not know

Where the sender works from, we do not know. The only clue was the time zone set in the message, and that is written by the sender's own software and fits several regions at once. It is not enough to draw a conclusion from.

We noticed that both companies whose names were used had at some point moved to a new main domain and left the old one running. It is possible the sender looks for exactly that kind of domain — alive, but abandoned, with nobody reading the complaints. It is also possible this is a coincidence: we have two examples. As a hunch it is interesting; as a finding it is not.

The addresses the sender asked people to reply to did not appear in any breach corpus we have access to, including logs from password-stealing malware. It looks as though the mailboxes were opened specifically for this run. We could not check the corpora we do not have access to.

That the mail never arrived, we established from mail logs and by looking directly in the organisation's mailboxes. Whether anyone received a copy at a personal address, we cannot check.

TLP:CLEAR — This document may be distributed without restriction.